

Gap ID	Evidence Status	Current State / Gap
G01	Confirmed	No clearly defined ISMS scope
G02	Confirmed	Security policies are incomplete
G03	Confirmed	No formal information asset inventory
G04	Confirmed	Risk assessments are inconsistent
G05	Confirmed	Security controls have not been formally selected
G06	Confirmed	No Statement of Applicability (SoA)
G07	Confirmed	Security awareness training is irregular
G08	Confirmed	Third-party security checks are inconsistent
G09	Confirmed from case scenario	Security risk decisions are largely reactive
G10	Evidence not provided	Formal information security objectives and measures are not evidenced
G11	Evidence not provided	Internal audit and management-review evidence is not provided

Risk Created	ISO Reference
ISMS boundaries and applicability are unclear; critical activities may fall outside governance.	Clause 4.3
Employees and control owners may apply inconsistent security requirements.	Clause 5.2; A.5.1
Critical assets may not have ownership, classification or appropriate protection.	A.5.9; A.5.12
Security risks may be evaluated differently or only after incidents occur.	Clause 6.1.2
Risk treatment decisions cannot be consistently demonstrated or monitored.	Clause 6.1.3
NovaPay cannot clearly evidence why controls apply, do not apply, or their implementation status.	Clause 6.1.3
Staff may be more susceptible to phishing, social engineering and policy violations.	A.6.3
Suppliers may introduce unmanaged access, cloud, data-processing or availability risk.	A.5.19-A.5.23
Incident-driven decisions can lead to inconsistent risk acceptance and delayed remediation.	Clauses 6.1, 8.1; A.5.24-A.5.27
Without measurable objectives, management cannot determine whether the ISMS is improving.	Clause 6.2; 9.1
Certification readiness cannot be demonstrated without independent review and management oversight.	Clauses 9.2 and 9.3

Recommended Improvement	Priority	Status
Define, approve and maintain a documented ISMS scope.	Critical	Open
Create an approved information security policy framework and supporting standards/procedures.	High	Open
Create an asset inventory, assign owners and establish classification requirements.	High	Open
Establish a repeatable risk methodology, criteria, risk register and review cadence.	Critical	Open
Create risk treatment plans and map selected Annex A controls to identified risks.	Critical	Open
Develop, approve and maintain a selected-control SoA for the case study; validate the full Annex A set for formal certification work.	Critical	Open
Implement mandatory onboarding and recurring awareness training with completion metrics.	High	Open
Implement supplier due diligence, contract security clauses, risk tiering and periodic review.	High	Open
Establish proactive risk and incident governance with defined owners and escalation criteria.	High	Open
Set measurable security objectives, metrics, owners and review frequency.	High	To Be Assessed
Establish an internal audit programme and formal management review before certification assessment.	Critical	To Be Assessed